

ShopSphere

S2 - Admin Authentication, RBAC and Access Control

Backend + DB

Platform-Specific Sprint Planning Document

This document intentionally defines only the behavior and delivery scope of the selected platform. It does not mix implementation details from the other platforms.

1. Sprint Definition

Sprint: S2 - Admin Authentication, RBAC and Access Control

Platform: Backend + DB

Application: ShopSphere

Objective: Implement the backend and database boundary for Admin Authentication, RBAC and Access Control, including business rules, persistence and API behavior.

This sprint is complete only when the stated use cases, acceptance criteria and tests pass for this platform.

2. Business Use Cases

ID	Use Case	Actor	Precondition	Main Flow	Expected Result
UC-01	Admin login	Admin	Valid admin identity	Submit credentials, authenticate, establish session	Admin reaches permitted dashboard area.
UC-02	Role-based access	Admin	Authenticated session with role	Open module/call API	Only permitted functionality is available.

3. Detailed Implementation Plan

1. Define admin roles and permission matrix.
2. Implement admin login/logout/refresh/me endpoints.
3. Implement authentication and authorization guards.
4. Reject customer tokens on admin APIs.
5. Record security/audit events for login and sensitive authorization failures.

4. Data / State / Contract Scope

- admin_users (or users with admin role)
- roles
- permissions
- user_roles

API / Integration Contract

- Feature APIs for this sprint, versioned under /api/v1.
- Every endpoint must define authentication, authorization, validation, error codes and request correlation.

5. Rules and Expected Behavior

- The platform must rely on the backend as the source of truth for business rules.
- Do not expose stack traces, secrets or internal implementation details to end users.
- Handle loading, empty, validation and error states explicitly.
- Requests that can be retried must be safe from duplicate side effects where the feature requires idempotency.
- Ownership and authorization must be checked server-side for protected data.

6. Acceptance Criteria

- Data model supports the required business relationships and constraints.
- API enforces authentication, authorization, validation and ownership where applicable.
- Business rules are server-authoritative.
- Transactions/idempotency/concurrency controls are used where the feature requires them.
- Controlled error codes and request correlation are implemented.

7. Test Cases

TC	Scenario	Expected Result
TC-S2-01	Wrong admin password	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S2-02	Expired token	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S2-03	Customer token on admin API	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S2-04	Role without permission	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S2-05	Direct forbidden URL	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S2-06	Revoked session	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S2-07	Concurrent logout	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.

8. Sprint Exit Checklist

- Implementation completed only for this platform.
- All primary and negative use cases pass.
- API contracts are implemented/consumed as defined.
- Validation and authorization tests pass.
- Loading/empty/error handling is verified where applicable.
- No critical or blocker defect remains.
- Automated tests pass in CI.
- Documentation and contract changes are committed.

9. Out of Scope for This Document

- Implementation behavior of Customer Portal. That behavior belongs in the separate S2 document for that platform.
- Implementation behavior of Admin Portal. That behavior belongs in the separate S2 document for that platform.